

ASSIGNMENT 2.1: ISO 27001 IMPLEMENTATION – STATEMENT OF APPLICABILITY

CLIENT: “SECURESOFT”, A SOFTWARE DEVELOPMENT COMPANY

PREPARED BY: NICHOLAS ATACHA

DATE: 19TH AUGUST 2026

1.0: INTRODUCTION

SecureSoft is a software development company. The company intends to implement an Information Security Management System (ISMS) and achieve ISO/IEC 27001:2022 certification.

From the risk assessment conducted, SecureSoft has identified four main risks. These are:

1. Unauthorized access to customer data
2. Loss of data due to hardware failure
3. Denial-of-service attacks on the company website
4. Vulnerabilities in software code developed of clients

The purpose of this Statement of Applicability is to document the assessment of all 93 controls in Annex A of ISO 27001:2022. This document will show which controls are required by SecureSoft, the reason for each decision, and the current implementation status.

2.0: STAEMENT OF APPLICABILITY TABLE

Annex A Reference	Control	Applicable	Justification	Implemented	Reference Document
A.5 organization I Controls – 37					
A.5.1	Policies for information security	Yes	Required to provide direction to address all four risks	Yes	Job Descriptions

A.5.2	Information security roles and responsibilities	Yes	Needed to assign responsibility for protecting customer data	Yes	Job Descriptions
A.5.3	Segregation of duties	Yes	Prevents one person from having full access to customer data	Yes	HR Policy
A.5.4	Management responsibilities	Yes	Management must approve and support security controls	Yes	Management Statement
A.5.5	Contact with authorities	Yes	Required to report cyber incidents to authorities	Yes	Incident Response Plan
A.5.6	Contact with special interest groups	Yes	Needed to get information about malware and DoS threats	Yes	Threat Intelligence Process
A.5.7	Threat intelligence	Yes	Helps to identify new malware and DoS attack methods	In Progress	Threat Report
A.5.8	Information security in project management	Yes	Security must be included in software projects	Yes	Project Management Policy
A.5.9	Inventory of assets	Yes	Needed know where sensitive customer data is stored	Yes	Asset Register

A.5.10	Acceptable use of information and assets	Yes	Reduces risk of malware from misuse of workstations	Yes	Acceptable Use Policy
A.5.11	Return of assets	Yes	Ensures laptops and returned when staff leave	Yes	Exit Procedure
A.5.12	Classification of information	Yes	Customer data must be marked as sensitive	Yes	Data Classification Policy
A.5.13	Labeling of information	Yes	Helps staff identify sensitive data	Yes	Labeling Guideline
A.5.14	Information transfer	Yes	Needed to transfer customer data safely	Yes	Data Transfer Policy
A.5.15	Access control	Yes	Direct addresses unauthorized access to customer data	Yes	Access Control Policy
A.5.16	Identity management	Yes	Needed to manage user accounts	Yes	Identity Management Policy
A.5.17	Authentication information	Yes	Protect passwords and login details	Yes	Password Policy
A.5.18	Access rights	Yes	Ensures only authorized staff access customer data	Yes	Access Rights Matrix

A.5.19	Information security in supplier relationships	Yes	Suppliers may handle customer data	Yes	Supplier Policy
A.5.20	Addressing security in supplier agreements	Yes	Security terms must be in contracts	Yes	Supplier Agreement
A.5.21	Managing information security in the ICT supply chain	Yes	Needed because we used third party software	Yes	Vendor Assessment
A.5.22	Monitoring supplier service	Yes	To ensure suppliers meet security requirements	Yes	Vendor Review
A.5.23	Information security for use of cloud services	Yes	SecureSoft uses cloud services	Yes	Cloud Security Policy
A.5.24	Information security incident management planning	Yes	Needed to respond to malware and DoS incidents	Yes	Incident Response Plan
A.5.25	Assessment and decision on information security events	Yes	To determine if an event is a security incident	Yes	Incident Procedure
A.5.26	Response to information security incidents	Yes	To handle malware and DoS attacks	Yes	Incident Response Plan

A.5.27	Learning from information security incidents	Yes	To prevent repeat of incidents	Yes	Lessons Learned Log
A.5.28	Collection of evidence	Yes	Needed for investigation of data breaches	Yes	Evidence Handling policy
A.5.29	Information security during disruption	Yes	To test security during system failure	Yes	Test Plan
A.5.30	ICT readiness for business continuity	Yes	Directly addresses Data loss and DoS risk	In Progress	Business Continuity Plan
A.5.31	Legal requirements	Yes	Software company must comply with data protection laws	Yes	Legal Compliance
A.5.32	Intellectual property rights	Yes	Protects company software code from theft	Yes	IP Policy
A.5.33	Protection of records	Yes	Customer data and logs must be protected	Yes	Records Management Policy
A.5.34	Privacy and protection of PII	Yes	Customer data contains personal information	Yes	Privacy Policy
A.5.35	Independent review of information security	Yes	To check if controls are working	In Progress	Audit Policy

A.5.36	Compliance with policies	Yes	To ensure staff follow security rules	Yes	Compliance Check
A.5.37	Documented operating procedures	Yes	Staff need clear steps to follow	Yes	SOP Manual
A.6.People Controls - 8					
A.6.1	Screening	Yes	To check background of staff with access to data	Yes	HR Screening Policy
A.6.2	Terms and conditions of employment	Yes	Staff must agree to security rules	Yes	Employment Contract
A.6.3	Information security awareness, education and training	Yes	Training reduces malware and data breach risk	Yes	Training Records
A.6.4	Disciplinary process	Yes	To act against staff who leak data	Yes	HR Disciplinary Policy
A.6.5	Information security when changing jobs	Yes	To remove access when staff change roles	Yes	Access Review
A.6.6	Information security for remote working	Yes	Some staff work from home with company data	Yes	Remote Work Policy
A.6.8	Termination or change employment	Yes	To remove access when staff leave company	Yes	Exit Checklist

A.7 Physical Controls – 14					
A.7.1	Physical security perimeters	No	SecureSoft has no physical office. Operations are cloud based	No Applicable	Not Applicable
A.7.2	Physical entry	No	No physical office	Not Applicable	Not Applicable
A.7.3	Securing offices	No	No physical office	Not Applicable	Not Applicable
A.7.4	Physical security monitoring	No	No physical office	Not Applicable	Not Applicable
A.7.5	Protecting against threats	No	No physical office	Not Applicable	Not Applicable
A.7.6	Working in secure areas	No	No physical office	Not Applicable	Not Applicable
A.7.7	Clear desk and clear screen	Yes	Prevents exposure of customer data on screens	Yes	Clean Desk Policy
A.7.8	Equipment	Yes	To protect company laptops and servers	Yes	Asset Management Policy
A.7.9	Security assets off-premises	Yes	Staff laptops contain customer data	Yes	Laptop Security Policy
A.7.10	Storage media	Yes	To securely delete data from old devices	Yes	Media Disposal Policy

A.7.11	Supporting utilities	No	Managed by cloud provider	Not Applicable	Not Applicable
A.7.12	Cabling security	No	Managed by cloud provider	Not Applicable	Not Applicable
A.7.13	Equipment maintenance	No	Managed by cloud provider	Not Applicable	Not Applicable
A.7.14	Secure disposal or reuse of equipment	Yes	To delete data before disposing devices	Yes	Disposal Procedure
A.8 Technological Controls – 34					
A.8.1	User endpoint devices	Yes	Directly addresses malware risk on workstations	Yes	Endpoint Security Policy
A.8.2	Privileged access rights	Yes	Limits access to sensitive customer data	Yes	Privileged Access Policy
A.8.3	Information access restriction	Yes	Prevents unauthorized access to data	Yes	Access Control List
A.8.4	Access to source code	Yes	Protects company software from theft	Yes	Source Code Policy
A.8.5	Secure authentication	Yes	MFA prevents unauthorized access	Yes	Authentication Policy

A.8.6	Capacity management	Yes	Helps to manage traffic during DoS attack	Yes	Capacity Plan
A.8.7	Protection against malware	Yes	Directly addresses malware infection risk	Yes	Anti-Malware Solution
A.8.8	Management of technical vulnerabilities	Yes	Patching closes holes used by malware	Yes	Patch Management Policy
A.8.9	Configuration management	Yes	Ensures systems are securely configured	Yes	Configuration Standard
A.8.10	Information deletion	Yes	To delete customer data when no longer needed	Yes	Data Deletion Policy
A.8.11	Data masking	Yes	Use fake data for testing	In progress	Data Masking Procedure
A.8.12	Data leakage prevention	Yes	Prevents customer data from leaving company	Yes	DLP Solution
A.8.13	Information backup	Yes	Directly addresses data loss from hardware failure	Yes	Backup Policy
A.8.14	Redundancy of information processing	Yes	Helps during DoS and hardware failure	Yes	Cloud Redundancy Setup

A.8.15	Logging	Yes	To detect unauthorized access	Yes	Logging Policy
A.8.16	Monitoring activities	Yes	To detect DoS and security incidents	Yes	SOC Monitoring
A.8.17	Clock synchronization	Yes	Needed for accurate log analysis	Yes	NTP Configuration
A.8.18	Use of privilege utility programs	Yes	Controls use of admin tools	Yes	Admin Tool Policy
A.8.19	Installation of software	Yes	Prevents installation of malware	Yes	Software Installation Policy
A.8.20	Network security	Yes	Protects website from DoS attacks	Yes	Network Security Policy
A.8.21	Security in networks	Yes	To monitor network for attacks	Yes	IDS/IPS
A.8.22	Segregation in networks	Yes	Separates customer data from other data	Yes	Network Segmentation
A.8.23	Web filtering	Yes	Block malicious websites that cause malware	Yes	Web Filter
A.8.24	Use of cryptography	Yes	Encrypts customer data to prevent breach	Yes	Encryption Policy

A.8.25	Secure system development lifecycle	Yes	Important for a software development company	Yes	SDLC Policy
A.8.26	Application security requirements	Yes	Security must be built into software	Yes	Requirements Document
A.8.27	Secure system architecture	Yes	To build secure systems	Yes	Architecture Document
A.8.28	Secure coding	Yes	Prevents coding errors that cause data breach	Yes	Coding Standard
A.8.29	Security testing	Yes	To test software before release	Yes	Test Report
A.8.30	Outsourced development	Yes	If development is outsourced, security must be checked	Yes	Outsourcing Agreement
A.8.31	Separation of developments environments	Yes	Separates test data from real customer data	Yes	Environment Policy
A.8.32	Change management	Yes	Controls change to software	Yes	Change Management Policy
A.8.33	Test Information	Yes	Do not use real customer data for testing	In progress	Test Data Policy
A.8.34	Protection of information systems during audit	Yes	To protect systems during audit	Yes	Audit Procedure

CONCLUSION

From the assessment above, SecureSoft has determined that 82 out of 93 controls in Annex A of ISO /IEC 27001: 2022 are applicable.

The remaining 11 controls have been assessed as not applicable. This is due to the fact that SecureSoft operates a fully remote, cloud-based model and does not maintain a physical office or own physical servers. All infrastructure and data processing are handled by third-party cloud service providers.

This Statement of Applicability will be reviewed annually or when there are significant changes to SecureSoft's business, processes, or risk profile.